

STRIDE project report

Authors: Davide Greco, Alberto Brignola, Filippo Gotta

Table of Contents

1. Introduction	2
1.1. Main assets	2
1.2. Assumptions	2
2. Modeling choices	2
2.1. Trust boundaries	3
3. Vulnerabilities	3
3.1. Legacy systems	3
3.2. Unencrypted communication	3
3.3. Physical access	3
3.4. Olympus portal	3
3.5. List of vulnerabilities	4

1. Introduction

In this project, we used the STRIDE (Spoofing, Tampering, Information disclosure, Denial of service, Elevation of privilege) framework to model and describe the Hephaestus Forge factory: an unmanned, fully automated printing facility producing titanium objects on demand.

1.1. Main assets

Given the factory structure, the identified main assets are:

- Projects and blueprints
- Finished products
- Titanium-X printers
- Slicer server and its proprietary software conversion
- reputation (intangible)

1.2. Assumptions

In our modeling, we assume that:

- firmwares are updates by flashing (no over-the-air updates)
- No known vulnerabilities in the internal servers
- Internal servers are not reachable by an external attacker
- Non-hosted, on premise IT infrastructure
- Servers and databases inside the perimeters of the factory
- Encrypted communications between the Olympus portal and the server, as well as any other internal communication not explicitly declared as in clear.
- Olympus portal communicates with the slicer server, sending the notification for new jobs to it while also storing the uploaded CAD file
- The slicer server converts the CAD file into G-code and store the product in the database
- As soon as a new CAD project gets uploaded, the corresponding G-code is generated
- No direct communication between slicer server and printers

2. Modeling choices

We considered the contractor and the web browser as untrusted entities, since we have no control over them. The client's web browser communicates only with the Olympus portal: it dispatches requests, and allows to store new projects. The authentication and session creation happens on server-side, hence they belong to a higher trust boundary (note that, since this process communicates with the Olympus portal, a vulnerability in it could compromise the whole trust boundary).

Since there is no proper separation between IT/OT departments (DMZ, firewalls...), we assume them to be in the same building, with the majority of the space occupied by the OT department (the IT departments however will have a stricter access policy).

When a new printing is requested, the slicer server sends the request to the Manufacturing Execution System (MES), which retrieves the corresponding G-code project from the database, and sends the request to one of the available printers (if there is none available, it will send it to a job queue).

As soon as a printer is available, the titanium powder gets refilled and the printing procedure starts. During this process, the printer's temperature gets constantly checked: if it gets too hot, the printing gets interrupted until we reach an acceptable temperature.

Once the process ends, the product is sent to a quality control scanner, that checks it with the original CAD file to see if it matches. If it does, it is added to the finished product's database.

2.1. Trust boundaries

Since we have no control over them, the client, its browser, and its email server are considered as untrusted entities. The IT/OT are in the same building, but we consider the IT to be at a higher trust level: anyone who manages to have access to the building will be able to access the OT equipment (printers, sensors, actuators, ...), while the IT will require some sort of credential verification. Everything else is considered to be safe, as it is not exposed to the external wall if not through the Olympus portal, is all in the same building and is controlled by us.

3. Vulnerabilities

3.1. Legacy systems

One of the biggest security hazards is the usage of windows XP, which has a quite lengthy list of known vulnerabilities (as shown on [opencve](#)); and since it reached its end-of-life in 2014 (for windows XP professional it was 2019) those will never be patched. Since machines are not updateable, the only solution is to either entirely change the printers with ones that support newer systems, or to create a compatibility layer that ensures they can run newer operating systems. Moreover, the ethernet protocol used cannot take advantage of encryption, as it needs to consider older systems that do not support it.

3.2. Unencrypted communication

Since internal communication is unencrypted, anyone who gets access to the factory's network connection can read and modify packets, effectively enabling them to do anything they want.

3.3. Physical access

If someone manages to get inside the factory's perimeter they could act freely, as it is an unmanned factory. This means the attacker can, for example:

- physically break hardware (printers, finished products, servers...)
- tamper with network devices (switches, internal services...)
- introduce malware such as keyloggers

To avoid this, we must ensure the presence of a strong physical barrier, as well as an effective intrusion detection system, and CCTV recordings that get periodically checked to spot anomalous presences.

3.4. Olympus portal

Perhaps the easier attack possible is a DDoS attack to the Olympus portal itself, being the single point from which all services are accessed. To avoid this, the usual DDoS mitigations techniques apply: we look for recognizable traffic patterns, bots and similar, and we try to filter out as many of those as possible, to guarantee the highest possible number of legitimate traffic to reach the server.

Then of course we need to make sure the Olympus portal's website is properly designed: being the single access point to the backend and the OT department, a vulnerability in it could have huge impacts on the whole factory, (e.g. as escalation of privilege, information leakage). To reduce the possibility of a social engineering attack to an admin that would lead to credential stealing, multi-factor authentication must be used. Moreover, it would be a good idea to allow access to the admin settings only if connected through the local network (for remote work a VPN could be used).

Another possible point of failure are the users' uploads: since we do not control them, we must check them thoroughly. This means we have to scan the uploaded CAD files to be sure they are not corrupted and they do not embed any malicious code, which could have serious implications, as it would run in the internal network (and hence it could spread anywhere)

3.5. List of vulnerabilities

Here is the complete list of vulnerabilities found:

Severity Frequency	Low	Medium	High	Critical
Very low	• CAD tampering (browser-portal)	• CSRF	• Path traversal	• CAD-embedded malware
Low	• Printer assigned to project	• Notification elimination • Forging requests • Modifying CAD information • MES overload • Modifying project data • Powder management tampering • Stop powder resupply	• Slicer server overloading • Slicer server compromised • API key leakage • Thermal sensor tampering • Thermal sensor spoofing • Sensor activity disruption • Quality control tampering	• Obtaining admin access • Old OS known vulnerabilities • EoP via known vulnerabilities
Medium		• Contractor information leakage • CAD tampering (OT floor) • G-code tampering • CAD leakage • G-code leakage	• Slicer spoofing • MES spoofing	
High		• Contractor impersonation • Account spoofing	• Portal overload	
Very high				